New Threat Model

Owner: Isaac Pyram
Reviewer:
Contributors:
Date Generated: Thu Apr 23 2026

Executive Summary

High-level system description

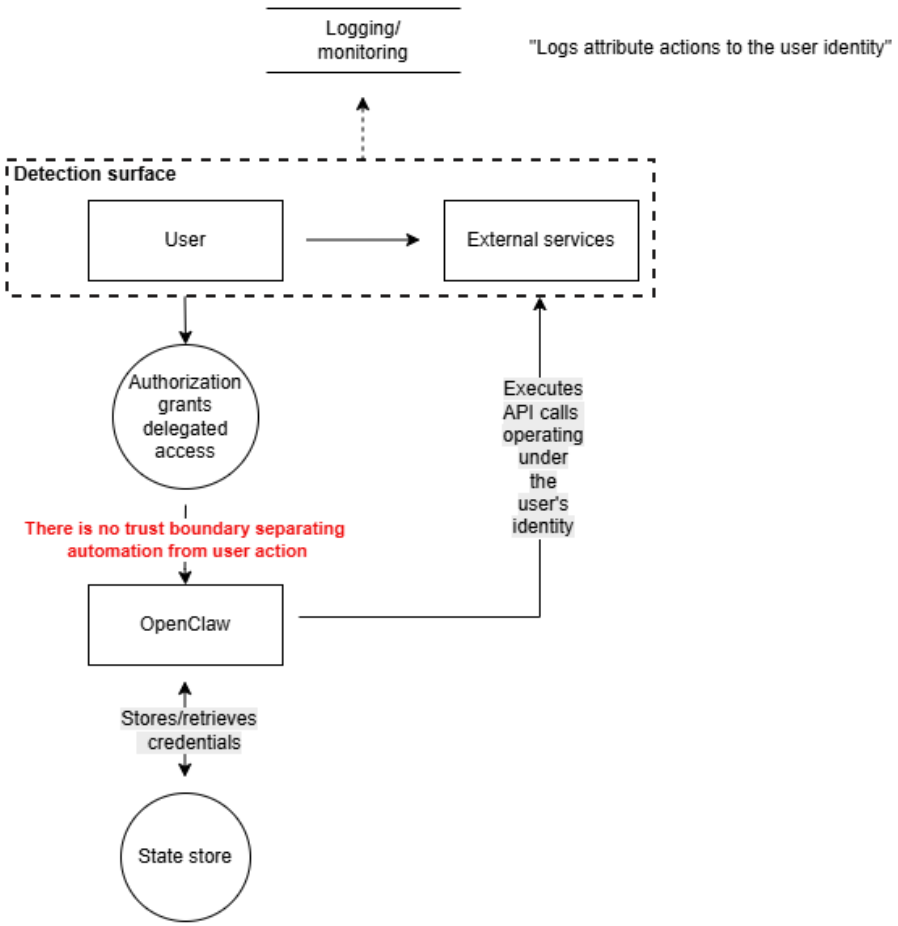
This model represents a workflow where a user delegates authority to an automation process (Open Claw) which executes API calls against external services. The automation operates using the user's delegated identity rather than a distinct automation principal. Open Claw interacts with a state store to manage workflow execution and context, and performs actions on external services that appear as if they originate from the user. Logging and monitoring systems observe activity primarily at the detection surface, capturing interactions between the user and external services. However, internal automation behavior, state transitions, and execution context are not fully observable. As a result, actions performed by the agent are logged under the user's identity, creating ambiguity between human-initiated and automated actions. This design introduces the risks related to identity attribution, delegated authority, and incomplete observability within the system.

Summary

Total Threats	**11**
Total Mitigated	**0**
Total Open	**11**
Open / Critical Severity	**5**
Open / High Severity	**5**
Open / Medium Severity	**1**
Open / Low Severity	**0**

OWASP Threat Dragon

New STRIDE diagram



Threat Analysis - DFD Flow Order

The sections below are ordered to mirror the DFD flow: delegation, automation execution, state management, external service impact, and logging/monitoring.

Authorization Grants Delegated Access (Process)

Number	Title	Type	Severity	Status	Description	Mitigations
1	Overly-broad delegated authority	Elevation of Privilege	Critical	Open	The authorization process grants Open Claw authority derived from the user identity without separation or any kind of boundary enforcement. As a result, the automation may inherit the full set of user privileges rather than only what is required to complete a task.	Introduce a distinct automation identity with scoped permissions. Replace broad delegation with short-lived, task-specific access controls aligned with least privilege.
2	Delegation lacks strong attribution linkage	Repudiation	High	Open	The delegation event is not strongly linked to downstream actions performed by the automation agent. This weakens the ability to determine whether an action originated directly from the user or from Open Claw.	Log delegation events with clear identifiers and correlate them with all previous automation actions using traceable context such as request IDs or session metadata.

Open Claw (Actor)

Number	Title	Type	Severity	Status	Description	Mitigations
3	Automation impersonates user operationally	Spoofing	Critical	Open	Open Claw performs actions using delegated user authority, making automated activity indistinguishable from direct user actions. This allows the automation to effectively impersonate the user during execution.	Execute automation under a distinct identity or role separate from the user. Ensure that all automatic actions preserve both the originating user context and the automation identity for clear attribution.
4	Compromise of automation leads to privilege misuse	Spoofing	Critical	Open	If Open Claw is compromised, it can use the delegated user authority to perform actions across external services with the same effective privileges as the user. This expands the impact of compromise beyond the automation environment.	Limit delegated permissions to the minimum required for each task. Isolate the automation environment and restrict its ability to access sensitive operations beyond its intended scope.

State Store (Process)

Number	Title	Type	Severity	Status	Description	Mitigations
5	Workflow state can be altered to influence automation behavior	Tampering	High	Open	The state store maintains workflow context and execution data used by Open Claw. Unauthorized modification of this state can influence automation behavior, leading to unintended or malicious actions without directly interacting with the automation process.	Restrict access to the state store and enforce integrity controls such as validation, versioning, and audit logging of all state changes.
6	State transitions are not fully observable	Repudiation	Medium	Open	Changes to workflow state may not be fully captured or correlated with automation actions	Log all state changes with timestamps and link them to automation actions using correlation identifiers to support traceability and investigation.

External Services (Actor)

Number	Title	Type	Severity	Status	Description	Mitigations
7	External services cannot distinguish automation from user	Spoofing	High	Open	External services receive API calls made under the user's delegated identity. As a result, they cannot distinguish between direct user actions and actions performed by Open Claw.	Use a distinct automation identity when interacting with external services and include contextual metadata to differentiate between user-initiated and automated actions.
8	Delegated access exposes data beyond intended scope	Information Disclosure	High	Open	Open Claw operates using delegated user authority and may access data or perform actions that exceed the intended scope of the automation task. External services will process these requests as valid, potentially exposing sensitive data unnecessarily.	Apply least-privilege access controls to all delegated permissions and restrict automation to only the specific resources and actions required for its functions.

Logging / Monitoring (Store)

Number	Title	Type	Severity	Status	Description	Mitigations
9	Logs misattribute automated actions to the user	Repudiation	Critical	Open	Logging and monitoring systems primarily observe activity at the detection surface and record actions under the user's identity. As a result, automated actions performed by Open Claw are indistinguishable from direct user activity in logs.	Capture and log both the originating user context and the automation identity. Include correlation identifiers to link delegation events, automation execution, and external service actions.
10	Automation activity lacks sufficient visibility for detection	Repudiation	High	Open	Internal automation activity, including execution flow and state interactions, is not fully visible to monitoring systems. This reduces the ability to detect anomalous or malicious behavior originating from Open Claw in a timely manner.	Extend monitoring to include detailed automation telemetry, including execution steps, state changes, and interaction with external services. Correlate this data with user and delegation context.
11	Shared identity model causes denial of service during incident containment	Denial of service	Critical	Open	When anomalous activity is detected and incident response actions are taken, containment requires disabling or restricting the compromised identity. Because Open Claw and the user share the same identity, this action removes access for both the automation and the human user. As a result, the legitimate user is denied access to their own environment during investigation and remediation.	Separate automation and human identities to allow independent containment actions. Ensure that incident response can isolate automation without impacting the user's access to critical systems.